BÁO CÁO BÀI TẬP THỰC HÀNH
HỌC PHẦN: PHÁT TRIỂN PHẦN MỀM WEB AN TOÀN

ĐỀ TÀI: CÀI ĐẶT HỆ THỐNG PHÁT HIỆN XÂM NHẬP SNORT VÀ THIẾT LẬP QUY TẮC PHÁT HIỆN TẤN CÔNG SQL INJECTION

Họ và tên sinh viên: Nguyễn Đức Dương

Lớp học phần / Sinh hoạt: D18CNPM2

Giảng viên phụ trách: Phương Văn Cảnh

Trường đào tạo: Trường Đại học Điện lực

I. MÔ HÌNH TRIỂN KHAI HỆ THỐNG

Thành phần	Máy Attacker (Tấn công)	Máy Target / NIDS (Giám sát)
Môi trường	Máy vật lý (Host)	Máy ảo Oracle VM VirtualBox
Hệ điều hành	Windows 11 64-bit	Ubuntu Server 22.04 LTS
Địa chỉ IP / Card mạng	192.168.1.11 (Wi-Fi DHCP)	192.168.1.15 / Interface: enp0s3 (Bridged)
Dịch vụ & Tiện ích	Command Prompt / cURL	Apache2 (Port 80) & Snort NIDS

II. QUÁ TRÌNH TRIỂN KHAI VÀ THỬ NGHIỆM

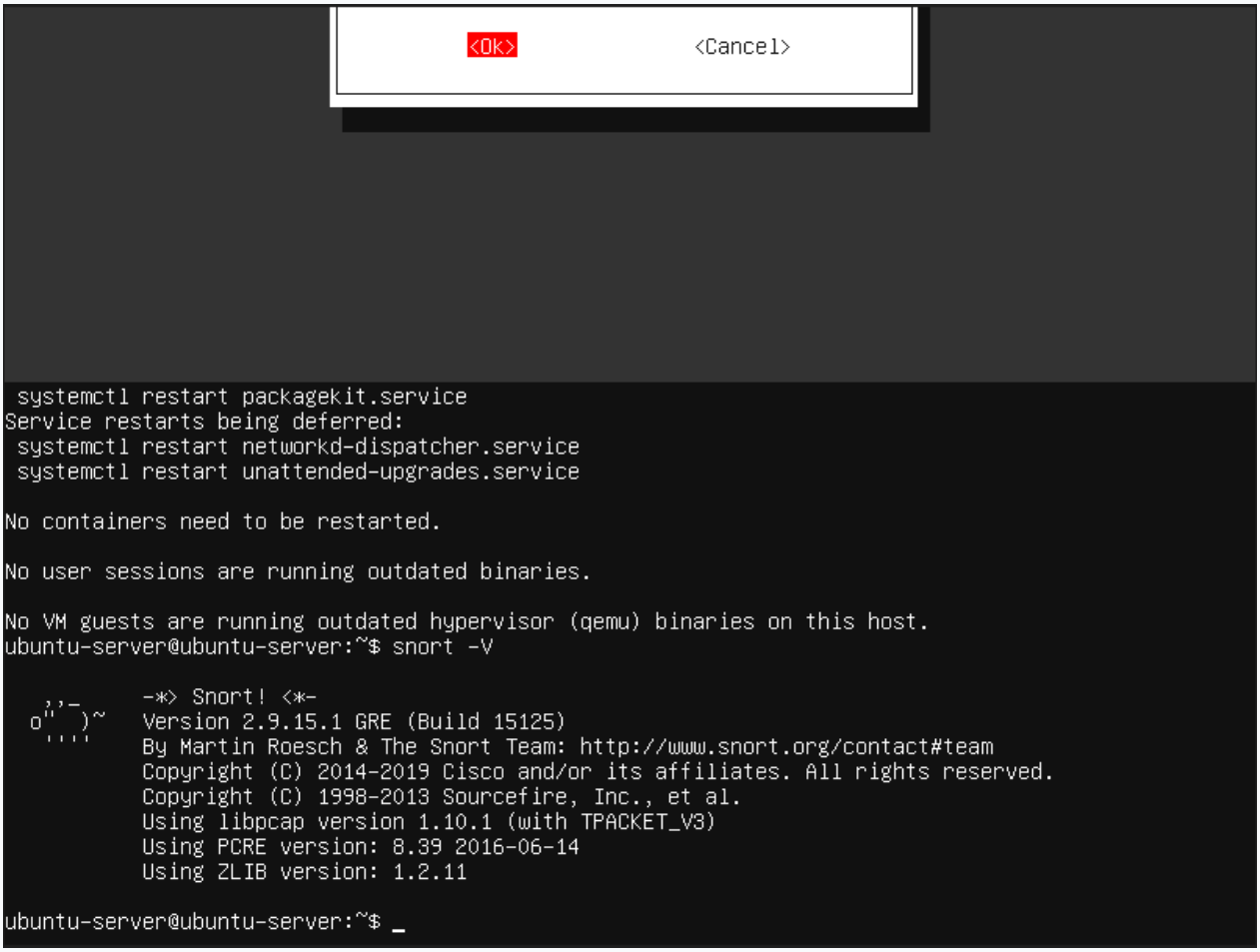
1. Cài đặt và kiểm tra trạng thái Snort

Cài đặt bộ công cụ Snort và máy chủ web Apache2 trên Ubuntu Server:

```
sudo apt update && sudo apt install -y apache2 snort
```

Kiểm tra phiên bản Snort đã cài đặt thành công:

```
snort -V
```



Hình: Minh chứng 1: Màn hình kiểm tra phiên bản Snort (snort -V)

2. Thiết lập quy tắc phát hiện tấn công SQL Injection

Thiết lập quy tắc giám sát lưu lượng hướng tới máy chủ tại file cấu hình rules:

```
alert tcp any any -> 192.168.1.15 80 (msg:"Phat hien tan cong SQL Injection"; content:"UNION"; nocase; content:"SELECT"; nocase; sid:1000001; rev:1;)
```



Hình: Minh chứng 2: Nội dung file quy tắc hiển thị trên terminal

3. Khởi chạy Snort ở chế độ bắt gói tin (IDS / Console Alert)

Khởi động tiến trình Snort lắng nghe trực tiếp trên card mạng enp0s3:

```
sudo snort -A console -q -c /etc/snort/rules/my_sql.rules -i enp0s3
```



Hình: Minh chứng 3: Snort khởi chạy ở chế độ console sẵn sàng nhận diện gói tin

4. Mô phỏng tấn công từ máy Windows 11 (Attacker)

Thực thi công cụ cURL từ máy thật Windows 11 mang tải trọng SQL Injection hướng tới cổng 80:

```
curl -d "UNION SELECT" http://192.168.1.15/
```

```
C:\Windows\System32>curl -d "UNION SELECT" http://192.168.1.15/
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.d
td">
<html xmlns="http://www.w3.org/1999/xhtml">
  <!--
    Modified from the Debian original for Ubuntu
    Last updated: 2022-03-22
    See: https://launchpad.net/bugs/1966004
  -->
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Apache2 Ubuntu Default Page: It works</title>
    <style type="text/css" media="screen">
  * {
    margin: 0px 0px 0px 0px;
    padding: 0px 0px 0px 0px;
  }

  body, html {
    padding: 3px 3px 3px 3px;

    background-color: #D8DBE2;

    font-family: Ubuntu, Verdana, sans-serif;
    font-size: 11pt;
    text-align: center;
  }

  div.main_page {
    position: relative;
    display: table;

    width: 800px;

    margin-bottom: 3px;
    margin-left: auto;
    margin-right: auto;
    padding: 0px 0px 0px 0px;

    border-width: 2px;
    border-color: #212738;
    border-style: solid;

    background-color: #FFFFFF;

    text-align: center;
  }

  div.page_header {
    height: 180px;
    width: 100%;

    background-color: #F5F6F7;
  }

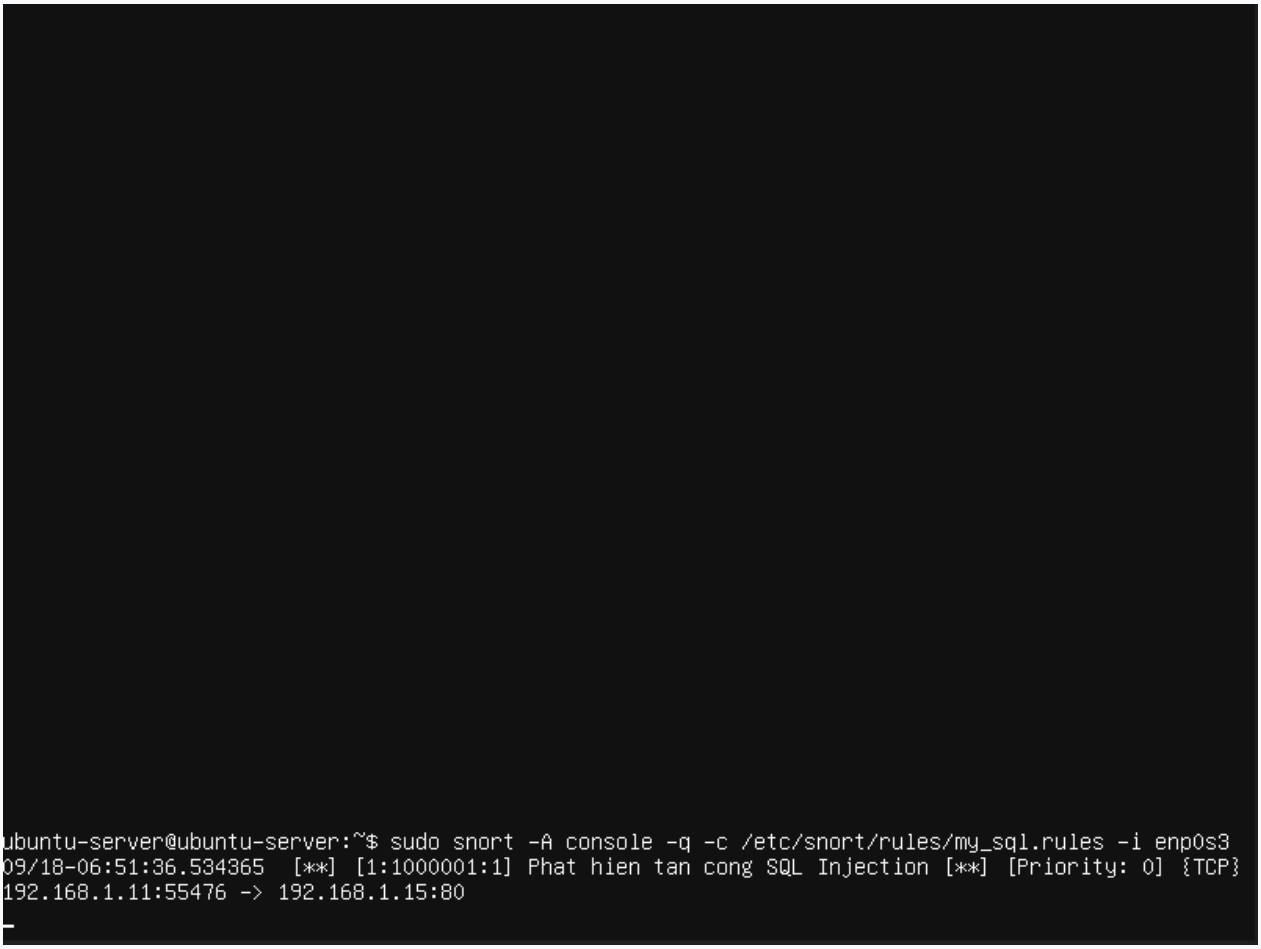
  div.page_header span {
    margin: 15px 0px 0px 50px;

    font-size: 180%;
    font-weight: bold;
  }
```

Hình: Minh chứng 4: Lệnh curl gửi payload từ Windows 11

5. Kết quả phát hiện xâm nhập của Snort

Snort phân tích phần tải trọng gói tin TCP và in thông báo cảnh báo trực tiếp ra màn hình console:



Hình: Minh chứng 5: Màn hình console của Snort in ra dòng cảnh báo phát hiện SQL Injection

III. PHÂN TÍCH VÀ ĐÁNH GIÁ KỸ THUẬT THEO YÊU CẦU

1. Nguyên nhân quy tắc (rule) khớp được gói tin tấn công:

• Kiểm tra tầng vận chuyển (Transport Layer): Gói tin được gửi qua giao thức TCP hướng tới địa chỉ IP đích 192.168.1.15 tại cổng dịch vụ 80 (HTTP).
• So khớp tải trọng (Payload Inspection): Snort phân tích sâu vùng dữ liệu (data payload) của gói tin HTTP POST/GET. Nhờ từ khóa content:"UNION" và content:"SELECT", hệ thống quét chuỗi ký tự thô trong gói tin. Tùy chọn nocase giúp quy tắc bỏ qua sự khác biệt chữ hoa/thường (bắt được cả 'union', 'select', 'UnIoN'...), từ đó khớp mẫu chính xác và kích hoạt alert.

2. Đánh giá ưu và nhược điểm của phương pháp match content thô:

• Ưu điểm:
  + Tốc độ xử lý cực nhanh: Giải thuật tìm kiếm chuỗi (như Boyer-Moore hoặc Aho-

Corasick) được tối ưu ở mức phần cứng/kernel, tiêu tốn rất ít CPU và RAM.
  + Dễ xây dựng và cấu hình: Cú pháp ngắn gọn, dễ triển khai ngay khi có mẫu tấn công đã biết (Signature-based).
• Nhược điểm:
  + Dễ bị vượt mặt (Evasion Techniques): Hacker có thể vượt qua bộ lọc bằng kỹ thuật obfuscation (như URL Encoding: %55NION, chèn comment inline: UN/**/ION, nối chuỗi HEX, hoặc khoảng trắng lạ).
  + Nguy cơ báo động nhầm (False Positive): Nếu người dùng thông thường gửi văn bản chứa từ 'union' hoặc 'select' trong ngữ cảnh bình thường (ví dụ: công đoàn, lựa chọn), Snort vẫn sẽ kích hoạt cảnh báo nhầm lẫn là cuộc tấn công.

3. Đề xuất phương án cải tiến hệ thống:

• Ứng dụng PCRE (Perl Compatible Regular Expressions): Sử dụng từ khóa pcre trong rule để kiểm tra cấu trúc biểu thức chính quy phức tạp, cho phép nhận diện các biến thể chèn comment, khoảng trắng bất thường hoặc dấu ngắt dòng. Ví dụ:
  pcre:"/union\s+(all\s+)?select/i";
• Kết hợp Preprocessor HTTP Inspect: Bật tiền xử lý http_inspect của Snort để chuẩn hóa (normalize) dữ liệu trước khi so khớp: giải mã URL (%20, %27), gom khoảng trắng thừa, loại bỏ các ký tự bypass tránh kỹ thuật né tránh.
• Giám sát theo ngữ cảnh (Contextual / Anomaly Detection): Giới hạn phạm vi kiểm tra vào đúng phần thân HTTP (http_client_body) hoặc tham số truy vấn (http_uri) thay vì quét toàn bộ gói tin thô.

IV. KẾT LUẬN

Hệ thống phát hiện xâm nhập Snort đã được cài đặt và vận hành ổn định trên Ubuntu Server 22.04 LTS. Quy tắc phát hiện tấn công SQL Injection hoạt động chính xác theo thời gian thực đối với các tải trọng khai thác cơ bản, đáp ứng đầy đủ các yêu cầu kỹ thuật và mục tiêu bài tập thực hành được giao.